

PR02: El eslabón más débil: diseño ético de una campaña de ingeniería social.

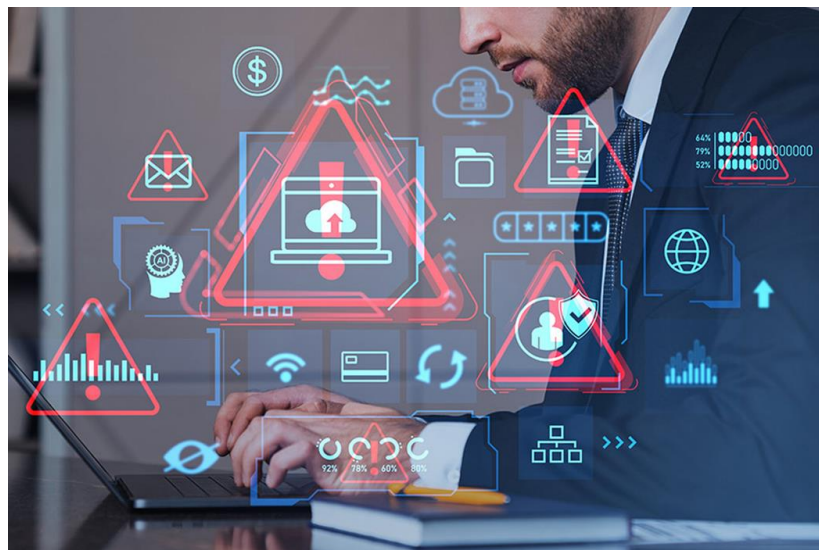
CNO V: Seguridad Informática

Gustavo Michael Larios Guerra - 178318

Investigación y simulación educativa de Phishing.

Objetivos del proyecto

Diseñar, implementar y evaluar de manera ética una simulación educativa de phishing, sustentada en el análisis comparativo de plataformas profesionales del mercado, con el propósito de medir el nivel de reconocimiento de amenazas de ingeniería social en usuarios, interpretar los resultados mediante un sistema de puntuación global y reflexionar sobre la gestión responsable del riesgo humano en seguridad informática.



Contenido

Investigación.....	3
1. Hoxhunt.....	3
2. Proofpoint (Security Awareness Training).....	3
3. KnowBe4	3
4. Cofense (antes PhishMe)	4
5. Phished.....	5
6. NINJIO	5
7. Mimecast (Awareness Training)	6
8. Infosec IQ	6
Tabla Comparativa.....	7

Investigación.

1. Hoxhunt

Características: Se basa en la gamificación extrema. No usa carpetas de "spam" estáticas; en su lugar, envía simulaciones adaptativas directamente a la bandeja de entrada. Si el usuario reporta el correo, gana puntos y sube en un ranking.

Enfoque Ético: Muy alto. Prioriza el refuerzo positivo (recompensar el reporte) sobre el castigo por hacer clic. Sus micro-aprendizajes duran menos de 1 minuto para no interrumpir la productividad.

Diferenciador Técnico: Utiliza IA Adaptativa para ajustar la dificultad de cada simulación individualmente. Si un usuario reporta tres correos seguidos, el cuarto será significativamente más difícil (más sutil).

Métrica Clave: Dwell Time (Tiempo de permanencia). Miden cuánto tiempo pasa desde que el correo llega a la bandeja hasta que el usuario lo reporta. Un tiempo bajo indica una cultura de alerta alta.

2. Proofpoint (Security Awareness Training)

Características: Su gran ventaja es la integración con su sistema de protección de correo (TAP). Utiliza ataques reales interceptados en la red para crear plantillas de simulación ("Attack Intelligence").

Enfoque Ético: Se centra en la identificación de VAPs (Very Attacked People). Permite dirigir el entrenamiento solo a quienes realmente están en riesgo, evitando saturar a toda la plantilla.

Diferenciador Técnico: Su integración con la pasarela de correo permite convertir ataques reales que han sido bloqueados en plantillas de simulación en cuestión de minutos.

Concepto VAP (Very Attacked People): Identifica automáticamente qué empleados están siendo el objetivo principal de hackers reales y les asigna entrenamiento extra de forma dinámica.

Uso: Ideal para empresas de nivel Fortune 500 que ya usan Proofpoint para proteger su infraestructura de correo.

3. KnowBe4

Características: Es el gigante del mercado con la biblioteca de contenido más grande del mundo. Destaca su IA llamada AIDA, que personaliza los escenarios de phishing según el historial de cada empleado.

Enfoque Ético: Utiliza el "Phish-prone %" (porcentaje de propensión al phishing). Su enfoque es de mejora continua, aunque a veces puede ser percibido como "punitivo" si no se configura bien la frecuencia de los tests.

Diferenciador Técnico: Su IA llamada AIDA (Artificial Intelligence Driven Agent) personaliza las recomendaciones de entrenamiento basándose en el historial de clics y la velocidad de aprendizaje del usuario.

Smart Groups: Permite automatizar grupos basados en criterios complejos (ej: "todos los usuarios de Finanzas que han hecho clic en un enlace en los últimos 3 meses").

4. Cofense (antes PhishMe)

Características: Fomenta la creación de una red de sensores humanos. Su botón "Cofense Reporter" es el eje central: cuando un usuario reporta, el sistema analiza el correo en tiempo real y puede borrarlo de todas las bandejas de la empresa automáticamente.

Enfoque Ético: Se basa en el empoderamiento. El usuario no es una víctima, es un "analista de primera línea" que ayuda a proteger a sus compañeros.

Diferenciador Técnico: Es la única plataforma cuyo eje central es el Botón de Reporte. El objetivo no es solo que el usuario no haga clic, sino que alimente al Centro de Operaciones de Seguridad (SOC).

Triage: Cuando un usuario reporta un correo (real o simulación), Cofense analiza el riesgo y ayuda al equipo de seguridad a eliminar ese correo de todas las bandejas de entrada de la empresa instantáneamente.

Ideal para: Equipos de seguridad que quieren reducir el tiempo de respuesta ante ataques reales.

5. Phished

Características: Plataforma 100% automatizada mediante IA. No requiere que el administrador elija plantillas; la IA estudia el perfil del usuario (LinkedIn, puesto, idioma) y lanza ataques de "spear phishing" personalizados automáticamente.

Enfoque Ético: Ofrece una "Academia de Phished" con rutas de aprendizaje individuales que se activan solo cuando se detecta una debilidad específica, respetando el ritmo de cada persona.

Diferenciador Técnico: Está diseñada para funcionar sin administrador. La plataforma hace el OSINT (búsqueda de información pública) de los empleados automáticamente para lanzar ataques de spear phishing muy creíbles.

Phished Assistant: Un "coach" de IA que vive en la bandeja de entrada y da consejos en tiempo real cuando el usuario duda de un correo.

Métrica: Behavioral Risk Score™, un puntaje de riesgo que predice la probabilidad de que un departamento específico sufra una brecha.

6. NINJIO

Características: Famosa por su contenido de vídeos estilo anime/cómic de 3 minutos, basados en ataques reales que ocurrieron esa misma semana. El storytelling es su arma principal.

Enfoque Ético: Utiliza la psicología del comportamiento. Al contar historias con las que el usuario empatiza, el aprendizaje es emocional y menos estresante que un test sorpresa tradicional.

Diferenciador Técnico: Su contenido se basa en ataques que ocurrieron en la vida real esa misma semana o mes. No es contenido genérico; es "noticia" convertida en aprendizaje.

Enfoque Psicológico: Identifica si un usuario es más susceptible a la Urgencia, la Autoridad o la Curiosidad, y adapta los videos de entrenamiento para atacar esa debilidad emocional específica.

7. Mimecast (Awareness Training)

Características: Muy similar a Proofpoint en cuanto a integración técnica. Sus videos de entrenamiento suelen usar el humor (la serie "Cyber Awareness") para mantener el compromiso del usuario.

Enfoque Ético: Mide el sentimiento del usuario y el riesgo por grupos. Su ética se basa en la transparencia de los datos de riesgo para que la gerencia entienda que la seguridad es una responsabilidad compartida.

Diferenciador Técnico: Incluye encuestas de sentimiento para medir si los empleados ven la seguridad como una carga o como parte de su responsabilidad.

Predictive Risk Scoring: Combina el comportamiento en las simulaciones con el comportamiento real del usuario en la navegación web y el uso de archivos para dar una nota de riesgo holística.

8. Infosec IQ

Características: Ofrece una flexibilidad técnica enorme con más de 2,000 recursos de formación. Permite crear "Phishing Assessments" muy profundos con simulaciones de smishing (SMS) y vishing (voz).

Enfoque Ético: Se alinea con marcos de cumplimiento como NIST o ISO 27001, asegurando que el entrenamiento cumpla con estándares legales y de privacidad de datos internacionales.

Diferenciador Técnico: Se especializa en el aprendizaje just-on-time. Si haces clic en un enlace prohibido, no solo sale una página de error; se abre instantáneamente un micro-módulo interactivo de 30 segundos sobre ese tipo exacto de ataque.

Personalización: Permite crear escenarios de Smishing (SMS) y Vishing (llamadas de voz automatizadas) muy complejos para simular ataques multi-canal.

Tabla Comparativa.

Plataforma	Capacidades Técnicas	Métricas de Medición	Enfoque de Entrenamiento	Controles Éticos (Gestión de Riesgo Humano)
Hoxhunt	IA Adaptativa que ajusta la dificultad por usuario; entrega asíncrona (no masiva).	Dwell Time (tiempo hasta el reporte) y Tasa de Reporte.	Gamificación extrema y micro-lecciones (< 1 min).	Fomenta el refuerzo positivo; prohíbe el uso de señuelos "creepy" (médicos o financieros reales).
Proofpoint	Integración con TAP; simulaciones basadas en ataques reales bloqueados por el gateway.	Identificación de VAPs (Gente Muy Atacada) y patrones de comportamiento.	Entrenamiento multicanal y "ZenGuide" (guía contextual).	Entrenamiento dirigido para evitar la fatiga por sobre-alerta; alta accesibilidad (WCAG).
KnowBe4	IA AIDA para personalización; SecurityCoach para alertas en tiempo real.	Phish-prone % (porcentaje de propensión) y Smart Groups automáticos.	Biblioteca masiva de contenido estilo "Netflix" (storytelling).	Transparencia en el roadmap de simulación; uso de "Teachable Moments" educativos.

Cofense	Foco en el botón de reporte; triaje automatizado en el SOC mediante IA.	Eficiencia del "Sensor Humano" y velocidad de mitigación.	El usuario como analista de primera línea (empoderamiento).	Human-in-the-loop: la IA solo sugiere, el humano decide para evitar falsos positivos punitivos.
Phished	Automatización Zero-Touch ; OSINT automático para personalizar el phishing.	Behavioral Risk Score™ (puntaje de riesgo conductual).	Rutas de aprendizaje dinámicas según el perfil de riesgo.	Evita el sobre-entrenamiento de perfiles de bajo riesgo; utiliza refuerzo positivo constante.
NINJIO	Storytelling de alta calidad (estilo anime); asociación con Defendify.	Conexión emocional y satisfacción del usuario (NPS).	Episodios mensuales cortos basados en noticias reales.	Se basa en la psicología de la empatía; evita el estrés por pruebas sorpresa agresivas.
Mimecast	Protección unificada para email y herramientas de colaboración (Slack/Teams).	Costo financiero del riesgo interno y brecha de acción-conciencia.	Vídeos de concienciación basados en el humor y el sentimiento.	Monitoreo de sentimiento del usuario para ajustar la agresividad de las campañas.
Infosec IQ	Multi-vector (Phishing, Smishing y Vishing con clonación de voz por IA).	Tasa de entrega de datos y tiempo de reporte de llamadas.	Aprendizaje <i>Just-on-time</i> (feedback instantáneo tras el clic).	Exclusión de temas de trauma personal; requiere aprobación ejecutiva para deepfakes de líderes.

Consideraciones.

La mayoría de dichas plataformas no son gratuitas, están enfocadas a un nivel empresarial (SaaS) diseñado para corporaciones, aunque existen alternativas de código abierto y versiones limitadas que pueden brindar información para comenzar con el aprendizaje.

- Las 8 plataformas que mencionamos (Hoxhunt, KnowBe4, etc.) son de pago.
- Modelo de negocio: Cobran por usuario al mes (ej. Hoxhunt ronda los 5€/usuario).
- Lo que sí ofrecen: Casi todas permiten una Demo gratuita o un Free Trial (prueba de 14-30 días).
- Excepción: Infosec IQ y KnowBe4 suelen tener "herramientas gratuitas" aisladas (como un test de phishing único para 100 usuarios), pero no la plataforma completa.

Plataformas Gratuitas y de Código Abierto (Open Source):

Gophish (La más recomendada): Es el estándar de la industria para código abierto.

Uso: La descargas, la instalas en tu PC o un servidor, y puedes crear campañas reales.

Ventaja: Tienes control total de los datos y el diseño. Es ideal para aprender la parte técnica.

King Phisher: Muy similar a Gophish, utilizada frecuentemente por "Red Teams" (hackers éticos) para pruebas de penetración. Es potente pero requiere más conocimientos técnicos de instalación.

CanIPhish (Versión Gratuita): Es una plataforma SaaS que tiene un "Tier gratuito perpetuo". Permite enviar un número limitado de correos al mes sin pagar, lo cual es perfecto para un ejercicio académico pequeño.

Referencias.

Página principal de Hoxhunt <https://hoxhunt.com/how-it-works>

¿Qué es Hoxhunt y cómo funciona? (Visión general y FAQ), <https://www.guardey.com/es/what-is-hoxhunt/>

ProofPoint: https://www.proofpoint.com/es/resources/threat-reports/human-factor-social-engineering?&hstk_creative=758188276002&hstk_campaign=19731365433&hstk_network=googleAds&gad_campaignid=19731365433

KnowBe4: https://info.knowbe4.com/es/sat-demo?gad_campaignid=23539054538

Cofense:

https://www.sentinelone.com/platform/purple/?igaag=168821150585&igaat=&igacm=21800889961&igacr=718770774141&igakw=purple%20ai&igamt=b&igant=g&campaign_id=21800889961&ad_id=718770774141&gad_campaignid=21800889961

Knowbe4: https://info.knowbe4.com/es/sat-demo?gad_campaignid=23539054541

Ninjio: <https://ninjio.com/>

Mimecast: <https://www.mimecast.com/es/>

Infosec IQ: <https://www.infosecinstitute.com/iq/>